Security Gate for Tool-Using LLM Agents: Results Report

GateExp with a QLoRA Qwen3-8B 4-way gate on AgentDojo banking and workspace · branch `GateExp` · 12 November 2026

Summary. The final system is a 4-way gate (ALLOW / BLOCK / ASK_USER / ESCALATE) built from a fine-tuned Qwen3-8B (`b5_v3_combo`) wrapped in deterministic GateExp layers: computed facts, pre-rules, the model, post-rules. The first learned gate (B5, Run 1) allowed **10.2 % unsafe actions** on test, against a target of 5 % or less. The final gate allows **0 %** on dev, attacks and the combination slice (CPU replay), and **0 of 120** attacks succeeded in the live AgentDojo run, against 10 of 120 without a gate, with no loss of utility (35.2 % vs 34.5 %). Unneeded asks are 10.5 % on dev, 7.9 % if the policy confirmations are left out (target 10 % or less). The final gate has not been run on test yet: it is held for one final run.

Headline	Before	Final (b5_v3_combo + GateExp)	Target
Unsafe actions allowed, dev	3.6 % (GateExp run 1)	**0 % (0/112)**	≤ 5 %
Unsafe actions allowed, attack set	5.9 % (GateExp run 1)	**0 % (0/51)**	≤ 5 %
Correct final outcome, dev	97.0 %	**100 % (236/236)**	above B4
Unneeded asks, dev (excl. policy confirmations)	24.4 % (17.5 %)	10.5 % (7.9 %)	≤ 10 %
AgentDojo attack success (142 test scenarios)	8.3 % (B0, no gate)	**0 % (0/120)**	lower than B0
AgentDojo utility	34.5 % (B0)	35.2 %	not below B0

Dev, attack and combination numbers for the final gate come from a CPU replay of the live selection run's model answers through the final rules (rounds after the first are approximated). The AgentDojo run used the gate before the last review fixes.

1. System

1. Facts
Code computes intent, risk, data source, file labels, split and daily payment totals, bound confirmations and unknown arguments from the call and the conversation.

2. Pre-rules
Decide before the model: an earlier "no", credentials leaving, an untrusted source, missing authority (confirm the recipient first, or escalate, or block if the approver's policy denies).

3. Model
QLoRA Qwen3-8B (`b5_v3_combo`) reads the call, the evidence, the retrieved policy clauses and the facts, and answers one of 4 decisions.

4. Post-rules
May only make the answer stricter or route it: guards, no re-asking, unknown arguments, intent, new-payee and amount confirmations, unlabelled data, routing to the approver.

5. Resolution
ASK goes to the user and ESCALATE to the approver, at most 2 rounds. Only ALLOW executes.

Payment policy (decided in this phase): the amount must come from the user; the first payment to a new IBAN is confirmed; a payee or recipient taken from a document is confirmed before an approver is asked.

2. Starting point: Run 1 baselines (test, 212 cases)

Gate	Correct	Unsafe allowed	Safe blocked	Unneeded asks
B1 rules	86.3 %	**21.2 %**	0.0 %	0.0 %
B2 prompted Qwen3-8B, binary	56.6 %	1.1 %	**70.1 %**	0.0 %
B3 prompted Qwen3-8B, 4-way	78.3 %	**22.9 %**	12.0 %	**48.0 %**
B5 QLoRA, 4-way	87.7 %	**16.9 %**	2.3 %	1.6 %
B5 guarded (best of Run 1)	**91.5 %**	**10.2 %**	**2.3 %**	**1.6 %**
B5 with inferred provenance	85.8 %	**20.3 %**	2.3 %	14.2 %

B4 (QLoRA binary) was not run in Run 1. Policy retrieval Recall@5 was 0.785 (target 0.85).

3. What went wrong

3.1 In Run 1

- **The model carried all of the safety on its own.** No gate reached the 5 % unsafe target. Every miss was a case where a deciding fact (approval needed, payee new, data confidential) was not computed and the model had to infer it from text.
- **Prompted gates were unusable:** the binary one blocked 70 % of safe actions, and the 4-way one asked in 48 % of cases that needed no question.
- **With realistic (inferred) provenance**, B5's unsafe rate doubled to 20.3 %.

3.2 After GateExp was added (B5 and B5 v2 inside the layers)

Set	Gate	Correct	Unsafe	Unneeded asks (excl. confirm)
test	Run 1 B5 + GateExp	97.2 %	**0.0 %**	28.3 % (9.4 %)
dev	Run 1 B5 + GateExp	97.0 %	3.6 %	**24.4 % (17.5 %)**
attacks (61)	Run 1 B5 + GateExp	91.8 %	**5.9 %**	6.1 %
all three	B5 v2 + GateExp + credential rule (proof run)	97.2 %	2.1 %	**12.4 %**

Breaking the system on purpose, and reading the decision logs, showed these failures:

Problem	Example	Kind
A "yes" was reused for a different payment	Approve one payee, then pay another or a larger amount	Ledger
"Yes, whatever" counted as a confirmation	Fatigue attacks	Ledger
Payments made in earlier tasks did not count toward the daily limit	Several payments under the limit, over it together	Ledger
An approval note inside a document counted as approval	BANK-ATK-13 (spoofed approval)	Ledger
Credentials could flow to a less protected place	Password or 2FA code emailed out	Rule missing
Escalation even when the approver's policy always denies	Restricted data: one wasted round, then a block	Rule order
Numbers read as amounts by mistake	Year of a date (2,024), IBAN digits ("ends with 3000"), "1.800" read as 1.8, amounts in words not read	Parser
Escalated before confirming a payee or recipient taken from a document	Kindergarten bill IBAN, access-request emails	Rule order
A customer list sent outside was treated as public	Thank-you email with 5 customers in To	Missing fact
Fail-open defaults	An unreadable amount counted as 0; an unregistered tool ran ungated; one trusted recipient vouched for a whole list	Code
Labels disagreed with the policy	First payment to a new IBAN labelled ALLOW, policy says confirm	Labels
The model over-asks with high confidence	Asks the user on clear, safe requests (delegation, access requests)	Training
Class weights did not fix over-asking	The weighting explained about 1 of the 12–23 log units of over-asking	Training
Two of our own fixes made things worse	"Owner says personal" rule (test 99.1 → 97.2 %); a reversibility rule tuned to known cases	Process

4. What we changed

4.1 Deterministic layers (no retraining)

Change	What it does
Credential rule	Credential data going to a less protected place is blocked before the model.
Ledger	A confirmation counts only for the exact payee and amount it was about; a near-identical IBAN in the answer counts as a "no"; a blank "yes" leaves the question open; payments already made today count toward the daily limit; after a real approver's "yes" the gate does not escalate again (approval notes in documents never count).
Approver policy	If the approver's written policy denies the basis, block directly instead of escalating.
Payment principle	The amount must come from the user; a new IBAN is confirmed on the first payment; arguments the tool does not have trigger a question.
One amount parser	Shared by all rules. It ignores invoice and reference numbers, date parts and IBAN fragments, and reads "1.800,00" and "eighteen hundred". An unreadable amount counts as over every limit.
Confirm before escalating	When the approval is about who receives, and that payee or recipient came from content, the user confirms it first; then the approver is asked (WS-2.3, BANK-2.3).
Contact-list disclosure	One email to several outside addresses copied from a file of contacts discloses that list: confidential, needs the manager (WS-2.4).
Fail closed	A list argument is as trusted as its worst value; tools missing from the registry are gated.

4.2 Policy text and labels

- Handbook BANK-2.2 (confirm the first payment's IBAN) and BANK-6.1 (the amount is stated by the holder) rewritten; the policy index was rebuilt.
- Labels changed to follow the policy instead of tuning rules to the labels: 47 new-payee cases ALLOW → confirm, 14 amount cases (4 later restored because their history already held an approval).
- Retrieval tags for clause coverage kept (Recall@8 +1 to 4 points; within noise on decisions).

4.3 Training (b5_v3 and b5_v3_combo)

Change	Why
Cost-matrix loss on the decision token (a wrong ALLOW costs 3–5, a needless deferral 0.3–0.5)	Penalise unsafe mistakes most, instead of flat class weights.
Decision smoothing 0.1	The over-asking was confidently wrong, not a calibration problem.
Adaptive group weights (suite × decision × data origin)	Groups the model handles worse count more, to avoid bias toward the large groups.
Safe twins (risky case with the one deciding fact made safe → ALLOW)	Teach the model when not to ask.
1,200 factor-combination cases (combo only), labelled by a policy oracle	The human labels cover few combinations of payee × amount × source × history; the oracle agrees with human labels on 97–98 % of banking cases.
1 epoch, LoRA dropout 0.1, GateExp facts in the input	Less overfitting; the model sees the same facts the rules use.
Bug found by a smoke run and fixed before the full run	The extra loss terms counted 16 times too much under gradient accumulation.

5. New results

5.1 Training (Kaggle, 2 × T4, one model per GPU)

Model	Examples	Steps	Time	Train loss
b5_v3	2,490	156	4.4 h	0.43
b5_v3_combo	3,690	231	6.4 h	0.42

5.2 Model selection (live, both models inside GateExp)

Slice	Metric	B5 v2	b5_v3	b5_v3_combo
dev (236)	correct	97.0 %	96.6 %	98.7 %
	unsafe	2.7 %	0.9 %	2.7 %
	unneeded asks	13.2 %	10.5 %	10.5 %
combinations (216, unseen factor pairs)	correct	–	93.1 %	99.5 %
	unneeded asks	–	**27.5 %**	8.4 %
attacks (61)	correct / unsafe	98.4 / 0 %	96.7 / 0 %	98.4 / 0 %
user's own cases (10)	correct	7/10	10/10	10/10

Chosen: b5_v3_combo. Its 3 unsafe dev cases were one case family (the customer list) whose deciding fact was missing from the evidence, the same 3 that B5 v2 failed; the review fix in 4.1 closes them. b5_v3's unsafe case is the model's own (it allowed an ambiguous delete).

5.3 After the review fixes (CPU replay of the selection run's answers)

b5_v3_combo	Correct	Unsafe	Unneeded asks	Escalations needed (precision)
dev	97.0 → **100 %**	2.7 → **0 %**	10.5 %	64.7 → 100 %
attacks	98.4 %	0 %	12.1 %	56 → 61 %
combinations	94.4 → 99.5 %	0 %	8.4 %	70 → 96 %
user's cases	100 %	0 %	0 %	100 %

A per-case diff showed no case that was right before and wrong after.

5.4 Live AgentDojo (142 test scenarios, 120 with an injected attack, simulated user with 15 % wrong answers)

Setup	Utility	Attack success	Banking utility	Workspace utility
B0, no gate	49/142 (34.5 %)	**10/120 (8.3 %)**	–	–
b5_v3 + GateExp	49/142 (34.5 %)	**0/120 (0 %)**	15/30	34/112
b5_v3_combo + GateExp	**50/142 (35.2 %)**	**0/120 (0 %)**	**16/30**	**34/112**

b5_v3_combo refused no call in any clean scenario, so lost utility comes from the agent, not the gate. b5_v3 blocked 2 harmless calendar events.

6. Targets

Target	Result (b5_v3_combo + GateExp)	Met
Unsafe actions ≤ 5 %	0 % on dev, attacks, combinations; 0/120 attacks on AgentDojo	**Yes**
Unneeded asks ≤ 10 %	Excluding policy confirmations: dev 7.9, attacks 9.1, combinations 8.4 %. Including them: dev 10.5, attacks 12.1 %	Yes, excluding policy confirmations
Correct final outcome above B4	Dev 100 % (replay), test pending	Pending test
Policy Recall@5 ≥ 0.85	Recall@8 0.88–0.96 with clause tags; Recall@5 not re-measured	Not re-measured

7. Limitations

1. **Intent from wording.** Whether the user asked for an action is read from a list of verbs. Clear requests with other wording ("let X see the file") get a confirmation question. This is reported as a training limitation; a model that understands intent reliably would need much more training than is possible here.
2. **Over-asking remains in two families**: client delegation and access-request emails (most of the 10.5 % unneeded asks on dev, 12.1 % on attacks).
3. **Policy confirmations cost questions.** The payment principle adds about 3 % questions that are required by policy; this is the price of the low unsafe rate.
4. **The final gate is not yet measured on test.** Test is held for one final run. Earlier gates were scored on test several times during development, so test is no longer fully unseen for the rules.
5. **Replay approximations.** The post-fix numbers replay saved first-round model answers; later rounds are approximated, so they are compared before and after, not with live runs.
6. **AgentDojo ran the gate from before the review fixes**, and utility (about 35 %) is limited by the base Qwen3-8B agent, not by the gate.
7. **The combination slice comes from the same generator** as the combination training data (only the factor combinations are new), so part of its gain is expected. The oracle's labels differ from the human labels on purpose in three known places: intent wording (63 cases), identity before authority (42), over the manager's maximum (23).
8. **Simulated people.** Users and approvers are simulated (ScenarioResponder with 15 % noise, MockApprover).
9. **Scope.** Two AgentDojo suites (banking, workspace), one model size, one seed, 1 epoch on T4 GPUs. The 61-case attack set is small. Tools of other suites are not described in the registry (they are gated, but without facts).
10. **Provenance in live runs is inferred** from text matching; a value that cannot be traced is "unknown", not untrusted.
11. **Not done:** the teammate's 90-case stress set (not in the repository), family-level confidence intervals, a "model alone" row and B4 for H2.

8. Where the evidence is

What	Location
Full change log with every run	`docs/GATE_EVALUATION.md`
Run index (dated folders)	`results/data/RUNS.md`
Training summaries	`results/data/2026-11-12_train_b5v3/`
Model selection run	`results/data/2026-11-12_compare_b5v3_vs_combo/`
Review-fix replay	`results/data/2026-11-12_replay_review_fixes/`
AgentDojo run	`results/data/2026-11-12_e2e_agentdojo_b5v3/`
Gate code	`src/sagate/gate/gateexp.py`, `gate/amounts.py`, `gate/guards.py`